CYBERSHIELD VAPT PLATFORM

Vulnerability Assessment & Penetration Testing Report

COMPREHENSIVE SECURITY AUDIT & RISK ANALYSIS

Target Environment:	Enterprise Security Environment (Multi-Asset Scope)
Assessment Type:	Comprehensive Multi-Vector Assessment
Audit Date:	October 25, 2026
Classification:	**CONFIDENTIAL - RESTRICTED DISTRIBUTION**
Prepared By:	CyberShield Automated Security Operations Center
Standard / Framework:	OWASP Top 10 / NIST SP 800-115 / PTES

Document Version 1.0 • Generated Automatically by CyberShield VAPT Engine

1. Executive Summary

During this assessment, CyberShield evaluated target assets for technical and architectural vulnerabilities. A total of **10 security findings** were identified across the specified scope, comprising **3 Critical**, **2 High**, **3 Medium**, **2 Low**, and **0 Informational** risks. Vulnerabilities rated as Critical or High represent immediate vectors that could permit unauthorized access, remote code execution, or credential theft, and should be prioritized for urgent remediation.

Critical	High	Medium	Low	Info	Total Findings
3	2	3	2	0	10

2. Assessment Scope & Rules of Engagement

All assessment activities were conducted strictly against authorized lab targets in compliance with explicit allowlisting controls. Testing methodologies incorporated automated port and service enumeration, application-layer vulnerability scanning, security header validation, and controlled non-destructive evidence verification.

Asset Name	Target Address / URL	Target Type	Authorization Status
Enterprise Security Environment	Multi-Asset Scope	LAB HOST	**Authorized Lab Scope**

3. Security Tooling & Architecture

Tool	Category	Function / Purpose
Nmap 7.94	Network Scanner	Port discovery, OS fingerprinting, and service version identification.
OWASP ZAP 2.14	DAST Scanner	Automated web application vulnerability auditing and HTTP header inspection.
Nessus Professional	Vulnerability Scanner	Enterprise CVE auditing and configuration compliance assessment.
Burp Suite Professional	Web Proxy / Scanner	Deep-layer manual and automated web flaw detection.
Metasploit Framework	Penetration Testing	Controlled validation and proof-of-concept evidence verification.

4. Detailed Technical Findings & Remediation

#1 • VAPT-2024-007: [156014] Apache Log4j Remote Code Execution (Log4Shell) **CRITICAL (CVSS: 10.0)**

Detection Source:	Nessus	**Status:**	Fixed
Affected Asset:	192.168.56.102:8080/tcp	**Verification:**	Verified / Confirmed
CVE Identifier:	CVE-2021-44228		

Description:

Apache Log4j versions 2.0-beta9 through 2.14.1 JNDI features do not protect against attacker-controlled LDAP and other JNDI endpoints. An attacker can execute arbitrary code loaded from remote servers.

Technical Impact:

Unauthenticated full remote code execution under the privileges of the JVM process.

Business Risk:

Total compromise of enterprise server, persistent backdoor deployment, and data destruction.

Remediation Roadmap:

Upgrade Log4j to version 2.17.1 or higher, or set JVM system property -Dlog4j2.formatMsgNoLookups=true.

Observed Evidence / POC Output:

```
Plugin Output: JNDI lookup payload triggered DNS token callback on test-listener.
```

#2 • VAPT-2024-001: Apache HTTP Server 2.4.49 Remote Code Execution & Path Traversal — CRITICAL (CVSS: 9.8)

Detection Source:	Nmap	**Status:**	In Progress
Affected Asset:	Port 80/tcp (Apache 2.4.49)	**Verification:**	Simulated Finding
CVE Identifier:	CVE-2021-41773		

Description:

Nmap version detection identified Apache HTTP Server 2.4.49. A flaw in URI path normalization in Apache HTTP Server 2.4.49 allows an attacker to map URLs to files outside the expected document root (Path Traversal) and execute CGI scripts remotely.

Technical Impact:

Complete unauthenticated remote code execution and reading of sensitive local configuration files.

Business Risk:

Catastrophic compromise of host confidentiality and potential lateral movement vector into corporate networks.

Remediation Roadmap:

Upgrade Apache HTTP Server immediately to version 2.4.51 or higher. Disable CGI execution if not required.

Observed Evidence / POC Output:

```
PORT 80/tcp open http Apache httpd 2.4.49 ((Debian)) Server: Apache/2.4.49
```

#3 • VAPT-2024-004: SQL Injection in User Authentication Endpoint (OWASP A03:2021)

CRITICAL (CVSS: 9.4)

Detection Source:	OWASP ZAP	**Status:**	Open
Affected Asset:	http://localhost:3000/rest/user/login (email param)	**Verification:**	Heuristic Alert
CVE Identifier:	CWE-89		

Description:

Automated payload injection detected potential SQL syntax error and boolean differentiation when testing payload `' OR 1=1--` against login handler.

Technical Impact:

Bypass of authentication controls, unauthorized administrative session acquisition, and database exfiltration.

Business Risk:

High risk of customer personal data breach and regulatory compliance penalties.

Remediation Roadmap:

Implement parameterized queries and input normalization using ORM frameworks. Avoid raw string concatenation in SQL expressions.

Observed Evidence / POC Output:

```
POST /rest/user/login Payload: {"email":"' OR 1=1--","password":"foo"} Response: SQLITE_ERROR: unrecognized token
```

#4 • VAPT-2024-008: [187311] OpenSSH Terrapin Attack Prefix Truncation Vulnerability — HIGH (CVSS: 8.1)

Detection Source:	Nessus	**Status:**	Fixed
Affected Asset:	192.168.56.102:22/tcp	**Verification:**	Verified / Confirmed
CVE Identifier:	CVE-2023-48795		

Description:

The SSH server uses cryptographic ciphers susceptible to sequence number manipulation, allowing adversaries to downgrade connection security.

Technical Impact:

Handshake sequence manipulation and security extension downgrades.

Business Risk:

Weakened cryptographic protection for remote system administration sessions.

Remediation Roadmap:

Upgrade OpenSSH to version 9.6p1 or newer, or disable ChaCha20-Poly1305 and CBC ciphers with ETM.

Observed Evidence / POC Output:

```
Observed chacha20-poly1305@openssh.com cipher in SSH KEX negotiation.
```

#5 • VAPT-2024-005: Reflected Cross-Site Scripting (XSS) in Search Endpoint (OWASP A03:2021) HIGH (CVSS: 7.5)

Detection Source:	OWASP ZAP	**Status:**	In Progress
Affected Asset:	http://localhost:3000/#/search?q=<script>	**Verification:**	Heuristic Alert
CVE Identifier:	CWE-79		

Description:

Input reflected unencoded into the response body. Payload `<svg onload=alert(1)>` was observed in client-rendered DOM without contextual HTML entity encoding.

Technical Impact:

Arbitrary JavaScript execution inside client browsers.

Business Risk:

Session hijacking, credential theft, and unauthorized user impersonation.

Remediation Roadmap:

Implement contextual output encoding (e.g., DOMPurify) and configure strict Content-Security-Policy headers.

Observed Evidence / POC Output:

```
GET /#/search?q=%3Csvg%20onload=alert(1)%3E Reflected in search header block.
```

#6 • VAPT-2024-002: MySQL Database Port Exposed Without Network Access Restrictions — MEDIUM (CVSS: 6.5)

Detection Source:	Nmap	**Status:**	Open
Affected Asset:	Port 3306/tcp (MySQL 5.7.34)	**Verification:**	Simulated Finding

Description:

The MySQL database listener port 3306 was found open and accessible across the network boundary, increasing exposure to brute force attacks.

Technical Impact:

Direct brute-force exposure and database authentication testing.

Business Risk:

Risk of unauthorized customer database dumping if default passwords exist.

Remediation Roadmap:

Bind MySQL strictly to 127.0.0.1 in my.cnf and enforce firewall iptables restrictions.

Observed Evidence / POC Output:

```
PORT 3306/tcp open mysql MySQL 5.7.34
```

#7 • VAPT-2024-009: [104743] TLS 1.0 and 1.1 Deprecated Protocol Enabled — MEDIUM (CVSS: 5.9)

Detection Source:	Nessus	**Status:**	Open
Affected Asset:	192.168.56.102:443/tcp	**Verification:**	Verified / Confirmed

Description:

The remote service accepts connections encrypted using TLS 1.0 or TLS 1.1. These protocol versions have known cipher suite deficiencies (BEAST, POODLE) and have been deprecated by RFC 8996.

Technical Impact:

Vulnerable to cryptographic eavesdropping and downgrade attacks.

Business Risk:

PCI-DSS and HIPAA non-compliance.

Remediation Roadmap:

Disable TLS 1.0 and TLS 1.1. Enforce TLS 1.2 and TLS 1.3 exclusively.

Observed Evidence / POC Output:

```
Offered TLSv1.0 with cipher TLS_RSA_WITH_AES_128_CBC_SHA
```

#8 • VAPT-2024-006: Missing Content-Security-Policy (CSP) Defense Header			MEDIUM (CVSS: 5.4)
Detection Source:	OWASP ZAP	**Status:**	Open
Affected Asset:	http://localhost:3000/ (HTTP Response Headers)	**Verification:**	Verified / Confirmed
CVE Identifier:	CWE-1021		

Description:

The HTTP response does not specify a Content-Security-Policy (CSP) header. CSP is a primary defense-in-depth header to restrict unauthorized script execution and framing.

Technical Impact:

Allows malicious injected scripts to fetch external payloads and transmit extracted credentials.

Business Risk:

Elevates the severity of XSS and clickjacking vulnerabilities across the application.

Remediation Roadmap:

Define a strong CSP header restricting script-src to 'self' and disabling inline script execution.

Observed Evidence / POC Output:

```
Response headers omitted Content-Security-Policy header completely.
```

#9 • VAPT-2024-003: OpenSSH Server Banner Information Disclosure			LOW (CVSS: 3.7)
Detection Source:	Nmap	**Status:**	Accepted Risk
Affected Asset:	Port 22/tcp (OpenSSH 8.9p1)	**Verification:**	Simulated Finding

Description:

The SSH service exposes its exact software version in the banner during initial protocol negotiation.

Technical Impact:

Facilitates reconnaissance by attackers identifying known OS distribution and package versions.

Business Risk:

Low operational impact; aids adversary reconnaissance phase.

Remediation Roadmap:

Modify sshd_config or banner settings where permissible.

Observed Evidence / POC Output:

```
PORT 22/tcp open ssh OpenSSH 8.9p1 Ubuntu
```

#10 • VAPT-2024-010: [10884] SNMP Agent Default Community Name (public)			LOW (CVSS: 3.2)
Detection Source:	Nessus	**Status:**	Open
Affected Asset:	192.168.56.102:161/udp	**Verification:**	Verified / Confirmed

Description:

The remote SNMP daemon responds to default community string 'public'. An unauthenticated attacker can query the SNMP agent to enumerate network interfaces, routing tables, and running processes.

Technical Impact:

Internal network topology and process enumeration.

Business Risk:

Information disclosure facilitating lateral movement planning.

Remediation Roadmap:

Change the default SNMP community strings or migrate to SNMPv3 with SHA/AES authentication and privacy.

Observed Evidence / POC Output:

```
SNMPv2c response obtained for community string: public
```

5. Conclusion & Strategic Guidance

The assessed infrastructure demonstrates baseline operational functionality; however, the presence of Critical and High severity findings requires immediate and disciplined mitigation. We advise development and operations teams to establish a 14-day remediation cadence for Critical CVEs and unauthenticated flaws, followed by a full re-test cycle to confirm vulnerability closure.

Lead Security Assessor	**Cybersecurity Operations Director**
_____	_____
CyberShield SecOps Lead	Head of Information Security